

A COMPOSITE CASE STUDY, BUILT AS A DATA PROTECTION IMPACT ASSESSMENT

Eleven Staff, One Trust

Dismissed This Year For Looking At Records They Had No Reason To See

What a regional shared care record actually shares, told through a composite case study spanning general practice, community mental health, and social care.

Reward Oladejo-Olagboye

Compliance Officer

This case study is entirely fictional.

Leah, the Ashcombe Integrated Care System, and every organisation named here are composite constructions created for professional development and portfolio purposes only. None represent any real individual, patient, service user, or organisation.

Leah's File

Leah is 34. She has a diagnosis of bipolar disorder, managed with support from a GP, a community psychiatric nurse who visits fortnightly, and a part time social worker. Until this year, each of these three professionals kept their own file on her, and mostly, that worked.

Then it didn't. Eight months ago, Leah called an out of hours GP service on a Sunday night, unsure whether to take an extra dose of her mood stabiliser. The duty doctor had never met her and had no access to her psychiatric notes. He gave sensible, generic advice. It was not what her own team would have told her, and Leah spent an anxious night before her nurse called the next morning.

This year, Ashcombe's GP practices, its community mental health trust, and its adult social care team began sharing a single care record to close exactly this gap. It worked. A second out of hours call, months later, went differently. The duty clinician could see her history and gave advice specific to her; not generic advice built for a stranger.

But the same system that closed one gap opened another. Three months in, Leah visited her GP for a sprained ankle. While the receptionist booked her follow up, Leah noticed her glance flicker, and pause, on a line that had nothing to do with her ankle: a safeguarding note her social worker had written over a year earlier, long since resolved. Nobody broke a rule. The receptionist had access because the system gave her access, not because she needed that note to book an appointment.

Leah did not complain. She also became noticeably more guarded with her GP afterwards, and it took her nurse several sessions to understand why. She never explicitly said. She did not need to.

Why This Is a Legal Requirement, Not a Courtesy

Information about a person's mental health is special category data under UK GDPR. Processing it needs both a lawful basis and a specific condition under Article 9, usually that it is necessary for health or social care. An organisation cannot hold it simply because doing so feels reasonable. It must name the legal ground and show real safeguards around who can see the data, how it moves, and how long it stays on record.

That is why this project cannot skip a Data Protection Impact Assessment. Under Article 35 of UK GDPR, a DPIA is mandatory wherever processing is likely to cause high risk, and this shared care record clears that bar several times over:

- Special category health data, processed at scale, across three organisations rather than one.

- Records matched and combined from previously separate systems into one composite file.

- Data belonging to a group generally recognised as vulnerable, exactly like Leah.

- A technology platform not previously used to link these three services together.

Meeting one of these criteria is often enough on its own. This meets four. The assessment has to happen before the record goes live, not after, which is exactly what Leah's file shows the cost of getting wrong.

What Changes at This Scale

The Data Security and Protection Toolkit, DSPT, is the annual self-assessment that CQC registered providers, NHS organisations, and their suppliers complete each year, measured against the National Data Guardian's ten data security standards. Smaller providers are assessed directly against those ten. Larger, higher risk organisations, NHS trusts and, increasingly, larger integrated arrangements like this one, sit in Category 1, and are assessed instead against a version aligned to the National Cyber Security Centre's Cyber Assessment Framework: four objectives covering how an organisation manages risk, protects against attack, detects incidents, and responds when something goes wrong.

DSPT added a fifth objective on top of these when it adopted the framework: using and sharing information appropriately. That objective exists because of exactly what happened to Leah. A system can be technically secure and still let the wrong person see the wrong thing.

Here, the controllers are a group of GP practices, an NHS community mental health trust, and a local authority social care team, jointly running a shared care record across the fictional Ashcombe Integrated Care System. It holds demographic details, medication records, safeguarding notes, care plans, and clinical correspondence, for a regional population in the tens of thousands, across systems that were never built to talk to each other before now.

The purpose, faster and safer decisions in urgent situations, is legitimate, and Leah's second out of hours call shows it working. What is less obvious is whether every member of staff needs full access to achieve that, or whether a narrower, role-based view would do the same job with less exposure. A GP receptionist booking a routine appointment does not need to see an eighteen-month-old safeguarding note. Where a summary view achieves the same safety outcome as a full record, proportionality points toward the summary, with full access available only on a documented reason.

This is not theoretical. NHS England issued a national warning earlier this year after a trust dismissed staff for exactly this kind of access, unrelated to the patients' care, and warned that unauthorised access can mean dismissal, regulatory referral, or prosecution.

Risk Assessment: Leah's Shared Care Record

Risk Area	Existing Control	Now	Mitigation	Target	CAF Objective
Inconsistent access controls across the three systems	No shared standard, each organisation manages its own logins.	Red	Single role-based access model, enforced across all three systems.	Green	Objective B, Identity and Access
No unified audit trail across the three organisations	Each system logs access locally, with no shared visibility.	Red	Shared audit log recording every access event, regardless of origin.	Amber	Objective C, Security Monitoring
Unclear breach ownership across more than one controller	No agreed lead organisation for a joint incident.	Amber	Joint incident protocol naming a lead organisation and notification timelines.	Green	Objective D, Response and Recovery
No data sharing agreement covering all three organisations	Sharing rests on informal understanding, not a signed agreement.	Red	Single tripartite agreement in place before going live.	Green	Objective E, Using and Sharing Information
Wider attack surface from newly connected systems	Each system was assessed in isolation, no joint architecture review.	Amber	Joint risk assessment of the integration, signed off by each IT lead.	Amber	Objective A, Risk Management
Staff outside a person's usual care team can view her full history	Full record access is granted to any authorised user by default.	Amber	Context sensitive access, summary view by default, full access on documented reason.	Green	Objective E, Using and Sharing Information
Retention periods differ across the three legacy systems	Each system retains records on its own local schedule.	Amber	Single retention schedule applied to the shared record.	Amber	Objective A, Governance
Individuals are not told their record is now shared across three organisations	Privacy notices refer only to each organisation's own use of data.	Amber	Updated privacy notices, plus a joint communication before going live.	Green	Objective E, Using and Sharing Information

Risk Area	Existing Control	Now	Mitigation	Target	CAF Objective
Subject access requests become more complex	No coordinated process for a request spanning more than one organisation.	Amber	Single coordinated process, with one nominated lead organisation.	Green	Objective E, Using and Sharing Information
Joint incident response has never been tested across all three	Each organisation has tested its own response separately.	Red	Joint tabletop exercise simulating a shared record breach before launch.	Amber	Objective D, Response and Recovery

Residual Risk, and What This Shows

Four risks stay amber even after mitigation: full audit alignment across three legacy systems, the wider attack surface created by connecting three previously separate systems for the first time, harmonising retention across those systems, and a joint incident response that has never actually been tested together. None of these meet the bar for mandatory ICO consultation under Article 36 once the other six mitigations are in place, but they are tracked deliberately, not assumed away. In practice, this assessment would need formal sign off from a Data Protection Officer at each organisation before going live, reviewed within twelve months or sooner if the scope changes.

Leah does not exist, but the pattern does. Three services, each careful on their own, become riskier the moment they are joined without also joining their governance. None of this needed a large budget to find. It needed someone to ask what changes when a record stops belonging to one organisation and starts belonging to a system, and to keep asking after it goes live, not only before.